Оцінювання ризиків в інформаційній системі

Будемо розглядати ризик як наявність невизначеності, яка пов'язана із настанням небажаної події, та збитками, які понесені внаслідок настання цієї події.

Ризик (за визначенням SEI (Software Engineering Institute)) – це можливість понести втрати.

Величина ризику представляє собою R = V * P – добуток обсягу втрат V від небажаної події в проекті та імовірності P настання цієї події.

Величина втрат V розглядається в контексті збитків внаслідок реалізації певних загроз, які актуальні для даної інформаційної системи, а імовірність P – як ступінь визначеності, з яким можна прогнозувати настання даної загрози.

Ефективне керування ризиками складається в прийнятті (по кожному ризику) компромісних рішень по:

- Врахуванню вразливостей, притаманних даній системи та відповідних ним загроз;
- Аналізу попереднього досвіду з попередніх ситуацій навмисного використання цих вразливостей чи завдання ненавмисної шкоди внаслідок наявних вразливостей;
- Оцінці трудомісткості усунення визначеного ризику;
- Оцінці обсягу потенційного небажаного впливу цього ризику на інформаційну систему.
- Оцінці взаємозалежностей ризиків, які мають бути усунуті, та можливого впливу прийнятих у визначений момент часу рішень на стан інформаційної системи в майбутньому.

<u>Концепція управління ризиком програмного забезпечення інформаційної системи</u>

Базові концепції керування ризиком:

- функції керування ризиком,
- таксономія (класифікація) ризику;
- методологія оцінки та керування ризиком.

<u>Ідентифікація ризику</u>

Ідентифікація ризику визначає, що може бути причиною потенційних втрат, причому має бути визначене наступне:

- Активи (первинні (тобто бізнес-процеси та пов'язана інформація)та підтримуючі (тобто апаратне, програмне забезпечення, персонал, розташування, заходи, організаційна структура);
- Загрози;
- Існуючі та заплановані заходи з безпеки інформації;
- Вразливості;
- Наслідки;
- Пов'язані бізнес-процеси.

На виході цього етапу має бути:

- перелік активів та пов'язаних бізнес-процесів, якими треба керувати методами управління ризиками, з відповідним переліком загроз, існуючими та запланованими заходами з безпеки інформації.
- Перелік вразливостей, що не має відношення до будь-яких ідентифікованих вразливостей.
- Перелік сценаріїв інцидентів безпеки з їх наслідками.

Оцінювання ризиків

Є два методи оцінки ризиків в області інформаційної безпеки: якісний та кількісний.

Кількісна оцінка ризиків

Чисто кількісний метод оцінки ризиків базується на математичних обчисленнях, які засновані на метриці безпеки активу (системи чи приложення). Для кожного сценарію ризику, беручи у розгляд різні фактори ризику, обчислюється сподівання одиничної втрати.

Очікування одиничної втрати (англ. – Single Loss Expectancy (SLE)) може бути визначене, як обсяг грошей, втрачений від настання небажаної події щодо якогось певного активу (пристроїв, програмного забезпечення, інформаційних баз тощо).

Математично цей показник виражається так:

$$SLE=AV*EF,$$

де *AV* (англ.- asset value)- обсяг активу, частка впливу *EF*(англ.- exposure factor) – представлений як вплив ризику на актив, або відсоток втрат активу. Наприклад, якщо актив був втрачений повністю, *EF*=1, або якщо актив втрачений наполовину, *EF*=0,5.

Далі, оцінюючи імовірність настання небажаної події в даний проміжок часу, наприклад, за допомогою щорічного співвідношення настання подій ARO (англ..- annual rate of occurrence) обчислюється щорічне очікування втрат *ALE(*англ.-annualized loss expectancy):

$$ALE=ARO*SLE.$$

Приклад. Припустимо, що актив оцінюється в $100,000, частка впливу EF для цього активу 25%. Тоді очікування одиничної втрати SLE = 25% * $100,000 = $25,000.

Для щорічного очікування трьох подій ARO = 3, ALE = 3 * $25,000 = $75,000.

Відмітимо, що при визначенні показника розглядаються всі активи, які брали участь в події, а не лише ті, які були прямо вражені.

Наприклад, якщо розглядається сценарій ризиків вразливості «Крадіжка офісного ноутбука», необхідно врахувати такі активи:

- цінність даних, що знаходились на даному ноутбуці;
- важливість втрати даних щодо інтересів компанії (дані можуть бути використані конкурентами);
- цінність самого ноутбука (апаратного забезпечення).

Для організації, наприклад, можуть розглядатись такі типи активів:

1. Інформація / дані (наприклад, файли, що містять цінну інформацію).
2. Аппаратні засоби (принтери, інша офісна техніка).
3. Програмне забезпечення, включаючи прикладні програми.
4. Обладнання для забезпечення зв'язку (наприклад, телефони, кабельна система).
5. Програмно-апаратні засоби (електронні носії інформації).
6. Документи (наприклад, контракти).
7. Продукція підпримства.
8. Послуги (наприклад, інформаційні, обчислювальні послуги).
9. Конфіденційність і довіра при наданні послуг (наприклад, послуг зі здійснення платежів).
10. Обладнання, що забезпечує необхідні умови роботи (система вентиляції-кондиціювання, протипожежна система і т.п.).
11. Персонал організації.
12. Престиж (імідж) організації.

Аналіз витрат та оцінка ймовірностей

Якщо в компанії розроблено бізнес-метрики, які можуть показувати вплив сценарію реалізації загрози на бізнес-показники, то ці метрики можуть застосовуватись при аналізі витрат в разі настання небажаних подій. Оцінка витрат по настанні небажаних подій може додатково контролюватись статистичними даними по величинам втрат в результаті інцидентів, що сталися, наприклад, за даними щорічного звіту "Cost of data breach study".

Для оцінки ймовірностей настання небажаних сценаріїв, пов'язаних із кожним фактором ризику, використовуються залежності цих ймовірностей від достатньої реалізації контрзаходів. Наприклад, можна використовувати просту шкалу: 3 – реалізовані контрзаходи цілком достатні, 2- реалізовані заходи недостатні, 1- контрзаходи відсутні. В якості довідників з описом контрзаходів можна використовувати профільні стандарти та керівництва, наприклад CobiT 5, ISO/IEC 27002 та інші. Кожен контрзахід має бути пов'язаний із конкретним фактором ризику.

Самі фактори ризику, характерні для багатьох бізнес-процесів, можуть виглядати так (укрупнено):

Персонал:

- Недостатня кваліфікація;
- Нестача співробітників;
- Низька мотивація.

Процеси:

- Часта зміна зовнішніх вимог;
- Нерозвинена автоматизація процесів;
- Суміщення ролей виконавцями.

Технології:

- Застаріле ПЗ;

- Низька відповідальність користувачів;
- Різнорідна структура IT-засобів.

За необхідності кожен із цих факторів може деталізуватись.

Якісна оцінка ризиків

Якісна оцінка ризиків виконується, коли є такі вимоги:
оцінка ризиків має бути виконана у відносно короткий термін;
треба вкластися у невеликий бюджет;
числові показники для оцінки кількості даних недоступні.

Якісна оцінка ризиків може бути виконана у коротший період часу та з меншими обсягами даних. Результат оцінки наводиться скоріше в описовій формі, ніж у кількісно-аналітичній. Наприклад, ризики оцінюються від «Дуже високого» до «Дуже низького».

Оцінка ризику проводиться в декілька етапів:
- оцінка наслідків за допомогою аналізу складу та обсягів активів;
- оцінка ймовірності інцидента безпеки за допомогою аналізу загрози чи вразливості;
- призначення числових величин наслідкам та ймовірності.

На виході такої оцінки надається список ризиків з відповідними рівнями ризику.

На протязі оцінки ризиків розглядаються три властивості даного активу (CIA): його конфіденційність (C), цілісність (I) та доступність(A). Інколи виділяють також спостережність.

Процес оцінки ризику вимагає результатів аналізу ризиків. На етапі оцінки ризиків із кожним елементом списку ризиків виконують такі дії: рівень ризику порівнюється з критерієм прийнятності ризику та ризики у списку сортуються за важливістю.

Відповідно до структури оцінки ризиків, запропонованих National Institute of Standards and Technology (США) (NIST SP 800-30), виконуються такі дії:
- збір інформації про загрози;
- побудова векторів атак та визначення, на які вразливості вони спрямовані;
- аналіз відповідних механізмів захисту;
- аналіз результуючого впливу атаки із врахуванням дії захисту (для того щоб вплив був вдалим, необхідно щоб булева функція успішності конкретного кроку атаки $загроза \wedge вразливість \wedge вада_захисту = True$);
- оцінка впливу інциденту на бізнес.

Методологія оцінки ризиків включає наступні первинні етапи:
- аналіз системи;
- ідентифікація загроз;
- аналіз контролю/засобів захисту;
- імовірність виконання атак;
- аналіз впливів атак;
- визначення ризиків;
- рекомендації по налаштуванню контроля/засобів захисту;
- вироблення результуючої документації.

Запобігання ризикам

Запобігання ризикам включає: пріоретизацію, оцінку та забезпечення контролю зменшення ризиків.